



CYBERSECURITY GUIDE

Subdomain Enumeration

Techniques, Tools, One-Liners & Best Practices
for Bug Bounty Hunters and Penetration Testers

● Passive & Active Methods ● 2025 Edition

Table of Contents

1. Introduction

2. Passive Enumeration Techniques

2.1 Search Engine Enumeration (Google Dorking)

2.2 Certificate Transparency (CT) Logs

2.3 DNS Aggregators & OSINT

2.4 Web Archives & Historical Data

3. Active Enumeration Techniques

3.1 DNS Brute-forcing

3.2 Virtual Host Enumeration

3.3 DNS Zone Transfers

3.4 Web Crawling

4. Essential Tools Deep Dive

4.1 Subfinder

4.2 OWASP Amass

4.3 Puredns + MassDNS

4.4 Gobuster & Ffuf

4.5 Httpx & Httpprobe

5. New & Emerging Tools (2024-2025)

6. One-Liners & Automation

7. Best Practices & Methodology

1. Introduction

Subdomain enumeration is the process of discovering subdomains associated with a target domain. It is one of the most critical phases in reconnaissance, bug bounty hunting, and penetration testing. 🎯

Organizations often host different services, APIs, staging environments, and internal tools on subdomains. Many of these receive far less security scrutiny than the main domain, making them prime targets for discovering vulnerabilities.

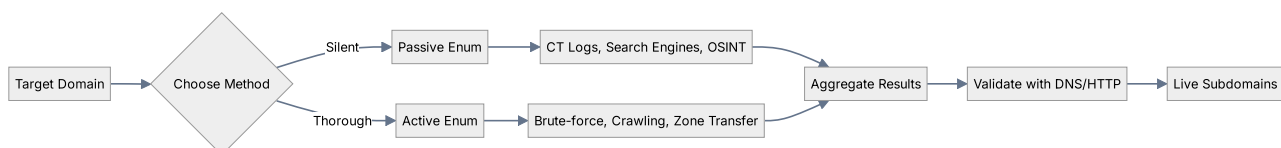
Why Subdomain Enumeration Matters

Expanded Attack Surface: More subdomains = more targets to test. **Shadow IT:** Forgotten subdomains may run outdated software. **Dev/Staging Leaks:** Test environments often lack proper security controls. **Takeovers:** Abandoned subdomains pointing to expired cloud resources can be claimed by attackers.

Two Approaches to Enumeration

Table 1 Passive vs Active Enumeration

Aspect	Passive Enumeration	Active Enumeration
Interaction	No direct contact with target	Sends requests to target servers
Stealth	Silent — no logs on target	Noisy — detectable by WAFs/IDS
Speed	Very fast (queries databases)	Slower (depends on rate limits)
Completeness	Limited to public records	Can find unlisted subdomains
Best For	Initial recon, stealth ops	Deep discovery, validation



2. Passive Enumeration Techniques

Passive techniques gather subdomains without ever sending a packet to the target. They query third-party databases, search engines, and public records. 🕵️

2.1 Search Engine Enumeration (Google Dorking)

PASSIVE METHOD

Search engines index billions of pages. Using advanced search operators, you can extract subdomains that have been crawled and indexed.

Key Google Dorks

GOOGLE DORKS

```
# Basic subdomain search
site:*.example.com

# Exclude www to find secondary subdomains
site:*.example.com -www

# Find subdomains with specific keywords
site:*.example.com inurl:admin

# Bing IP search for related hosts
ip:192.168.1.1

# Deep subdomain enumeration
site:*.example.com
```

Automated with Tools

AUTOMATED SEARCH

```
# Using Subfinder (queries search engines automatically)
subfinder -d example.com -sources censys,shodan

# TheHarvester for email + subdomain OSINT
theHarvester -d example.com -b google,bing,yahoo
```

2.2 Certificate Transparency (CT) Logs

PASSIVE METHOD

Certificate Transparency is an open framework for monitoring and auditing SSL/TLS certificates. Every certificate issued is logged publicly, revealing subdomains that may not be advertised

anywhere else. 🗝️

Popular CT Sources

- **crt.sh** — Free web interface to CT logs
- **Google Certificate Transparency** — Google-hosted logs
- **CertSpotter** — Automated CT monitoring
- **Censys** — Search engine for certificates

CT LOG QUERIES

```
# Query crt.sh via curl + jq
curl -s "https://crt.sh/?q=%example.com&output=json" | \
  jq -r '.[].name_value' | sed 's/\*\./g' | sort -u

# Using ct-exposer (Python tool)
python3 ct-exposer.py -d example.com

# Using CertCrunchy for bulk analysis
certcrunchy -d example.com -o certs.json
```

Pro Tip

CT logs often reveal **internal** and **staging** subdomains that organizations secured with SSL but never intended to be public. Look for patterns like `dev-*.example.com`, `vpn.example.com`, or `*.internal.example.com`.

2.3 DNS Aggregators & OSINT

PASSIVE METHOD

DNS aggregators collect historical and current DNS records from sensors worldwide. These databases reveal subdomains that existed even briefly in the past.

Table 2 DNS Aggregator Sources

Source	Type	Best For
VirusTotal	Free/Paid	Historical resolutions + subdomains
SecurityTrails	Paid API	Enterprise-grade historical DNS
Shodan	Free/Paid	Exposed services + banners

Censys	Free/Paid	Certificate + host data
DNSDumpster	Free Web	Quick visual DNS map
Netcraft	Free	OSINT + site technology
WhoisXML API	Paid API	Comprehensive subdomain DB

API USAGE

```
# SecurityTrails API
curl "https://api.securitytrails.com/v1/domain/example.com/subdomains" \
  -H "APIKEY: YOUR_API_KEY" | jq -r '.subdomains[]' | \
  sed 's/$/.example.com/'

# VirusTotal (requires free API key)
curl -s "https://www.virustotal.com/vtapi/v2/domain/report?\
  apikey=YOUR_KEY&domain=example.com" | jq -r '.subdomains[]?'

# Shodan host search
shodan search "hostname:example.com" --fields hostnames
```

2.4 Web Archives & Historical Data

PASSIVE METHOD

Web archives store snapshots of websites over time. By analyzing historical captures, you can discover subdomains that were previously linked but are no longer advertised.

ARCHIVE SOURCES

```
# Wayback Machine (via gau tool)
gau example.com --threads 10 --subs | unfurl -u domains | sort -u

# Common Crawl data
curl -s "http://index.commoncrawl.org/CC-MAIN-2024-51-index?\
  url=*.example.com&output=json" | jq -r '.url' | \
  unfurl -u domains | sort -u

# AlienVault OTX
otxurls -d example.com | unfurl -u domains | sort -u
```

3. Active Enumeration Techniques

Active techniques directly interact with the target's infrastructure. They are more thorough but generate noise and can trigger alerts. ⚡

3.1 DNS Brute-forcing

ACTIVE METHOD

Brute-forcing involves systematically testing potential subdomain names against the target's DNS servers using a wordlist. It is one of the most effective ways to discover hidden subdomains that exist in no public database.

Wordlist Strategy

Table 3 Recommended Wordlists

Wordlist	Size	Source / Generation
subdomains-top1million-110000.txt	110K	SecLists — excellent starting point
n0kovo_subdomains	3M+	Generated from real CT log data
commonspeak2	500K+	Google BigQuery DNS traffic data
AssetNote Wordlists	Various	Targeted, frequently updated
Custom Permutations	Variable	Generated with Gotator / mksub

BRUTE-FORCING COMMANDS

```
# Puredns + MassDNS (fastest resolver-based brute-force)
puredns bruteforce wordlist.txt example.com \
  -r resolvers.txt -o resolved.txt

# Gobuster DNS mode
gobuster dns -d example.com -w wordlist.txt \
  -t 50 --delay 100ms -o gobuster_results.txt

# Ffuf with HTTP validation
ffuf -w wordlist.txt -u https://FUZZ.example.com \
  -mc 200,301,302 -t 100 -rate 50

# Amass brute-force mode
amass enum -brute -d example.com -w wordlist.txt \
  -o amass_brute.txt
```

Rate Limiting Warning

DNS brute-forcing generates thousands of queries. Always use **public DNS resolvers** (e.g., 8.8.8.8, 1.1.1.1, 9.9.9.9) — never brute-force through the target's own nameservers. This is not only noisy but may violate terms of service or scope rules.

3.2 Virtual Host Enumeration

ACTIVE METHOD

Virtual host enumeration discovers subdomains hosted on the same IP address by sending HTTP requests with different `Host` headers. This reveals hidden sites not listed in public DNS.

VHOST DISCOVERY

```
# Ffuf vhost enumeration
ffuf -w subdomains.txt -u http://target_IP \
  -H "Host: FUZZ.example.com" -fs 1234

# Gobuster vhost mode
gobuster vhost -u http://example.com \
  -w wordlist.txt --append-domain

# Using httpx for validation
cat vhosts.txt | httpx -title -status-code -tech-detect
```


3.3 DNS Zone Transfers

ACTIVE METHOD

A DNS zone transfer (AXFR) is a type of DNS transaction used to replicate DNS databases across nameservers. Misconfigured servers may allow anyone to request a full zone dump — instantly revealing every record.

ZONE TRANSFER ATTEMPT

```
# Using dig
dig axfr @ns1.example.com example.com

# Using host command
host -t axfr example.com ns1.example.com

# Using dnsrecon (automated)
dnsrecon -d example.com -t axfr

# Using fierce (finds nameservers then attempts AXFR)
fierce --domain example.com
```

Reality Check

Zone transfers are **increasingly rare** on modern infrastructure. However, they still occur on internal DNS servers, legacy BIND configurations, and misconfigured cloud DNS setups. Always test during engagements — it takes seconds and can yield complete domain maps.

3.4 Web Crawling

ACTIVE METHOD

Modern web applications use microservices and API endpoints, each often with its own subdomain. Web crawlers analyze links, JavaScript files, and API responses to discover these dynamically.

CRAWLING COMMANDS

```
# Katana (ProjectDiscovery crawler)
katana -u https://example.com -d 5 -jc -o katana_out.txt

# Hakrawler (Go-based fast crawler)
echo "https://example.com" | hakrawler -subs

# Burp Suite passive crawling
# Start spider from target scope, collect subdomains from responses

# Gospider (multithreaded)
gospider -s "https://example.com" -d 3 --subs
```

4. Essential Tools Deep Dive

4.1 Subfinder

PASSIVE TOOL

Subfinder by ProjectDiscovery is the industry-standard passive subdomain scanner. It queries 30+ sources in parallel and outputs clean, deduplicated results. 🚀

Table 4 Subfinder Overview

Attribute	Details
Language	Go
Type	Passive only
Sources	30+ (CT logs, search engines, APIs, archives)
Speed	Very fast (parallel goroutines)
Output	JSON, TXT, CSV

SUBFINDER USAGE

```
# Basic scan
subfinder -d example.com

# All sources (requires API keys in ~/.config/subfinder/provider-config.yaml)
subfinder -d example.com -all -o results.txt

# JSON output for pipeline integration
subfinder -d example.com -oJ subs.json

# Silent mode (output only subdomains)
subfinder -d example.com -silent

# Multiple domains
subfinder -dL domains.txt -o subs.txt
```

4.2 OWASP Amass

HYBRID TOOL

Amass is OWASP's flagship attack surface mapping tool. It combines passive OSINT with active DNS enumeration and builds a graph database of relationships between domains, IPs, and ASNs.



Table 5 Amass Modes

Command	Mode	Use Case
<code>amass enum -passive</code>	Passive only	Stealth reconnaissance
<code>amass enum -active</code>	Active enumeration	Deep discovery with DNS queries
<code>amass enum -brute</code>	Brute-force	Discover hidden subdomains
<code>amass viz</code>	Visualization	Generate network graphs (DOT, D3)
<code>amass db</code>	Database	Query stored enumeration data

AMASS EXAMPLES

```
# Passive enumeration
amass enum -passive -d example.com -o amass_passive.txt

# Active with brute-force
amass enum -active -d example.com -brute -w wordlist.txt \
    -o amass_active.txt

# Track with timeout and verbose
amass enum -d example.com -timeout 12 -v

# Generate D3.js visualization
amass viz -d3 -o amass_graph.html

# Install (Kali: preinstalled / macOS: Homebrew)
brew tap owasp-amass/homebrew-amass && brew install amass
```

4.3 Puredns + MassDNS

ACTIVE TOOL

Puredns is a high-performance DNS resolver and brute-forcing tool. It wraps **MassDNS** with wildcard detection, deduplication, and validation. Together they form the fastest DNS brute-force pipeline available. ⚡

PUREDNS SETUP & USAGE

```
# Prerequisites: MassDNS + public resolvers
# 1. Install MassDNS
git clone https://github.com/blechschmidt/massdns.git
cd massdns && make && sudo make install

# 2. Install Puredns
go install github.com/d3mondev/puredns/v2@latest

# 3. Get resolvers (trim to ~1000 for stability)
wget https://raw.githubusercontent.com/trickest/resolvers/main/resolvers.txt

# Brute-force with wildcard filtering
puredns bruteforce wordlist.txt example.com \
    -r resolvers.txt -w wildcards.txt -o live_subs.txt

# Resolve existing list
puredns resolve candidate_subs.txt -r resolvers.txt -o resolved.txt
```

4.4 Gobuster & Ffuf

ACTIVE TOOLS

Both tools are fast, parallel HTTP/DNS fuzzers. **Gobuster** is purpose-built for enumeration with clean output. **Ffuf** is a general-purpose web fuzzer with unmatched flexibility. 🔥

GOBUSTER DNS & VHOST

```
# DNS brute-force
gobuster dns -d example.com -w wordlist.txt -t 100 -o gobuster_dns.txt

# Virtual host discovery
gobuster vhost -u https://example.com -w subs.txt \
    --append-domain -k

# Directory enumeration (bonus)
gobuster dir -u https://sub.example.com -w dirs.txt -x php,html
```

FFUF ADVANCED

```
# Subdomain brute-force over HTTPS
ffuf -w wordlist.txt -u https://FUZZ.example.com \
    -mc 200,204,301,302,401,403 -t 100

# VHost fuzzing
ffuf -w vhosts.txt -u http://TARGET_IP \
    -H "Host: FUZZ" -fs 1234 -t 80

# Recursive fuzzing with extensions
ffuf -w wordlist.txt -u https://FUZZ.example.com \
    -recursion -recursion-depth 2 -e .html,.php,.json
```

4.5 Httpx & Httpprobe

VALIDATION TOOL

Not every discovered subdomain resolves or serves HTTP. **Httpx** and **Httpprobe** validate which subdomains are actually live web servers and gather metadata.

HTTP PROBING

```
# Httpx (ProjectDiscovery – feature-rich)
cat subdomains.txt | httpx -title -status-code -tech-detect \
  -o live_http.txt

# Httpx with screenshot + follow redirects
cat subs.txt | httpx -sc -title -location -td \
  -follow-redirects -o detailed.txt

# Httpprobe (lightweight alternative)
cat subdomains.txt | httpprobe -p http:8080 -p https:8443 \
  >> live_servers.txt

# Fast multi-concurrency probe
cat subs.txt | httpx -threads 200 -timeout 5 -retries 1
```

5. New & Emerging Tools (2024-2025)

The reconnaissance landscape evolves rapidly. Here are the most impactful new tools and updates that have changed workflows in 2024-2025. 

Table 6 New Tools Comparison

Tool	Author/Source	Language	Key Innovation
DarkScout	DarkScout Team	Rust	Lightning-fast scanning, minimal resource usage
Chaos	ProjectDiscovery	Go	Continuously updated DNS dataset API
Gotator	Trickest	Go	High-speed permutation generation
mksub	Trickest	Go	Wordlist refinement from discovered patterns
shuffledns	ProjectDiscovery	Go	MassDNS wrapper with wildcard filtering
Katana	ProjectDiscovery	Go	Modern headless crawler with JS execution
THEXRECON	Thexnumb	Go	All-in-one recon automation framework

DarkScout

2025 RELEASE

Written in Rust for maximum performance, DarkScout targets bug bounty hunters who need instant results. It is lighter and faster than Subfinder for basic recon but lacks the deep OSINT

correlation of Amass.

DARKSCOUT USAGE

```
# Install via cargo or binary release
cargo install darkscout

# Fast single-domain scan
darkscout -d example.com -o subs.txt

# Bulk scan
cat domains.txt | darkscout -o all_subs.txt
```

Chaos

PROJECTDISCOVERY

Chaos queries ProjectDiscovery's continuously updated DNS dataset. It often finds unique subdomains not available through standard passive sources.

CHAOS USAGE

```
# Requires free API key from chaos.projectdiscovery.io
chaos -d example.com -silent -o chaos_subs.txt

# With JSON output
chaos -d example.com -json -o chaos.json

# List subdomains with IP
chaos -d example.com -silent | dnsx -a -resp
```

Permutation Engines: Gotator & mksub

Modern permutation engines analyze discovered subdomains to generate likely variations. This dramatically improves brute-force efficiency.

PERMUTATION WORKFLOW

```
# 1. Collect base subdomains
subfinder -d example.com -o base.txt

# 2. Generate permutations with Gotator
gotator -sub base.txt -perm permutations.txt -depth 2 \
    -numbers 10 -o permuted.txt

# 3. Refine with mksub (pattern-based)
mksub -l base.txt -w custom_wordlist.txt -o refined.txt

# 4. Resolve with Puredns
puredns resolve permuted.txt -r resolvers.txt -o live.txt
```

6. One-Liners & Automation

The real power of reconnaissance comes from chaining tools together. Here are battle-tested one-liners for rapid subdomain enumeration. 🔧

PASSIVE Quick Passive Recon

Fast passive enumeration using Subfinder + Chaos + Assetfinder

```
subfinder -d example.com -silent; chaos -d example.com -silent; assetfinder -subs-only example.com | sort -u
```

ACTIVE Full Brute-Force Pipeline

Brute-force + resolve + validate with Puredns + dnsx + httpx

```
puredns bruteforce wordlist.txt example.com -r resolvers.txt -w wildcards.txt |
dnsx -a -resp | httpx -title -status-code
```

COMBO All-in-One Recon

Passive collection → permutation → brute-force → live validation

```
(subfinder -d example.com -all -silent; amass enum -passive -d example.com -
timeout 10) | anew base.txt | gotator -sub - -perm perms.txt -depth 1 | puredns
resolve -r resolvers.txt | httpx -o live.txt
```


COMBO CT Log + Archive Harvest

Extract subdomains from CT logs and Wayback Machine in one go

```
(curl -s "https://crt.sh/?q=%example.com&output=json" | jq -r '[][.name_value' |  
sed 's/\\*\\.//g'; gau example.com --subs | unfurl -u domains) | sort -u
```

AUTOMATION Continuous Monitoring

Cron-friendly script to detect new subdomains and alert on changes

```
subfinder -d example.com -silent | anew subs.txt | notify -bulk -id subdomain-  
alerts
```

ACTIVE VHost Discovery Pipeline

Find hidden virtual hosts via IP then validate HTTP responses

```
ffuf -w subdomains.txt -u http://TARGET_IP -H "Host: FUZZ.example.com" -fs 0 |  
httpx -title -status-code -tech-detect
```

COMBO Enterprise Recon Script

Comprehensive recon combining Amass, Subfinder, and custom wordlists

```
amass enum -passive -d example.com -o amass.txt &  
subfinder -d example.com -all -o subf.txt &  
wait; cat amass.txt subf.txt | sort -u | puredns resolve -r resolvers.txt | httpx  
-probe-status -o live_final.txt
```

AUTOMATION Subdomain Takeover Check

Check discovered subdomains for potential takeover vulnerabilities

```
subfinder -d example.com -silent | dnsx -cname | nuclei -t http/takeovers/ -silent
```

7. Best Practices & Methodology

Complete Enumeration Workflow



Key Recommendations

1. Always Start Passive

Begin with passive sources to build your baseline without alerting the target. Use Subfinder, CT logs, and DNS aggregators before sending any active probes.

2. Use Multiple Wordlists

No single wordlist is perfect. Combine SecLists, n0kovo_subdomains, commonspeak2, and custom permutations generated from your target's naming conventions.

3. Rotate DNS Resolvers

Use a curated list of 500-1000 reliable public resolvers. Rotate them to avoid rate-limiting and improve accuracy. Never brute-force through the target's nameservers.

4. Respect Scope & Rate Limits

Bug bounty programs often have strict scope and rate-limiting rules. Use `-rate` flags, implement delays, and follow `robots.txt` guidelines. Aggressive scanning can get you banned from programs.

5. Automate & Monitor

Set up continuous monitoring for high-value targets. New subdomains appear constantly — weekly or daily scans with `anew + notify` ensure you never miss an opportunity.

Tool Selection Matrix

Table 7 When to Use Which Tool

Scenario	Recommended Tool	Command Pattern
Quick initial scan	Subfinder + Assetfinder	<code>subfinder -d target -all; assetfinder target</code>
Deep reconnaissance	Amass (passive then active)	<code>amass enum -active -brute -d target</code>
Fast brute-force	Puredns + custom wordlist	<code>puredns bruteforce wl.txt target -r resolvers.txt</code>
Virtual host discovery	Ffuf or Gobuster vhost	<code>ffuf -w subs.txt -u http://IP -H "Host: FUZZ"</code>
Validate live web servers	Httpx	<code>cat subs.txt httpx -title -sc -td</code>
Crawl for more subs	Katana or Gospider	<code>katana -u https://target -subs</code>
Continuous monitoring	Subfinder + anew + notify	<code>subfinder -d target anew subs.txt notify</code>

Legal & Ethical Reminder

Only perform subdomain enumeration on systems you own or have explicit written permission to test. Unauthorized scanning may violate laws including the Computer Fraud and Abuse Act (CFAA) and similar legislation worldwide. Always follow responsible disclosure practices. ⚖️

Recommended Resources

- **SecLists** — github.com/danielmiessler/SecLists (wordlists)
- **Trickest Resolvers** — github.com/trickest/resolvers (DNS resolvers)
- **ProjectDiscovery Tools** — github.com/projectdiscovery (Subfinder, Httpx, Chaos, Katana)
- **OWASP Amass** — github.com/owasp-amass/amass
- **AssetNote Wordlists** — wordlists-cdn.assetnote.io